

Лекция 02



Контекст продукта и требования безопасности

**Как из контекста конкретного продукта
получить проверяемое требование безопасности?**

Факультет компьютерных наук

Бакалаврская образовательная программа 09.03.04 «Программная инженерия» · 3 курс

Дисциплина «Разработка безопасного программного обеспечения» · 2026/2027 учебный год



Секция 1

Контекст как источник требования

Требование появляется из смысла продукта, а не из готового списка



После семинара 01 у нас уже есть контекст

3 / 45

Граница продукта

что входит в продукт и
за что отвечает
команда



Пользователи и роли

кто взаимодействует с
продуктом и с какими
полномочиями



Основные сценарии

какие значимые
действия выполняются



Значимые активы

какие данные, функции
или состояния важно
защищать



Какие свойства безопасности нужны именно этому продукту?



Предметное правило — ещё не требование безопасности

4 / 45

Предметное правило (бизнес-правило)

— ограничение или порядок работы продукта, вытекающий из его назначения и предметной области. Проверяемость правила сама по себе не делает его требованием безопасности. Для SR нужно обосновать значимое защитное свойство и последствия его нарушения в контексте продукта.

Примеры правил системы выдачи оборудования

у одного студента одновременно может находиться не более трёх устройств

заявка автоматически закрывается через N дней после подтверждённого возврата устройства



Когда появится защитный смысл

5 / 45

1 у одного студента одновременно может находиться не более трёх устройств

2 изменять запись о выданном устройстве может только уполномоченный сотрудник

У какого правила уже есть очевидный защитный смысл и почему?



есть значимое защитное свойство и последствия нарушения?



нет → остаётся предметным
правилом продукта



да → появляется основание
для требования безопасности



Как углубить контекст до защитного смысла

6 / 45

Роль и полномочие

не «авторизованный пользователь», а студент, кладовщик, тот, кто вправе подтвердить операцию

Значимость актива

не только запись: персональные данные, достоверность реестра, корректность текущего владельца

Конкретное действие

чтение, изменение, удаление, подтверждение, передача, выгрузка

Неприемлемое состояние

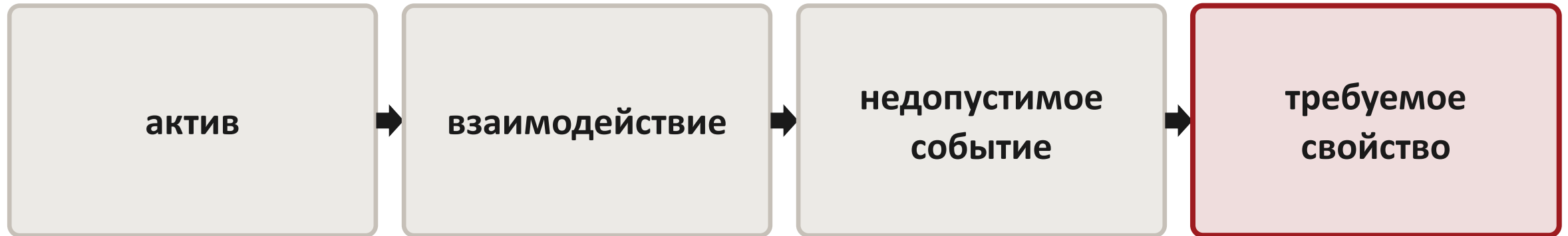
какое действие или состояние продукта нарушает требуемое свойство

**Чем конкретнее роль, актив, действие и недопустимое состояние,
тем легче сформулировать проверяемое свойство**

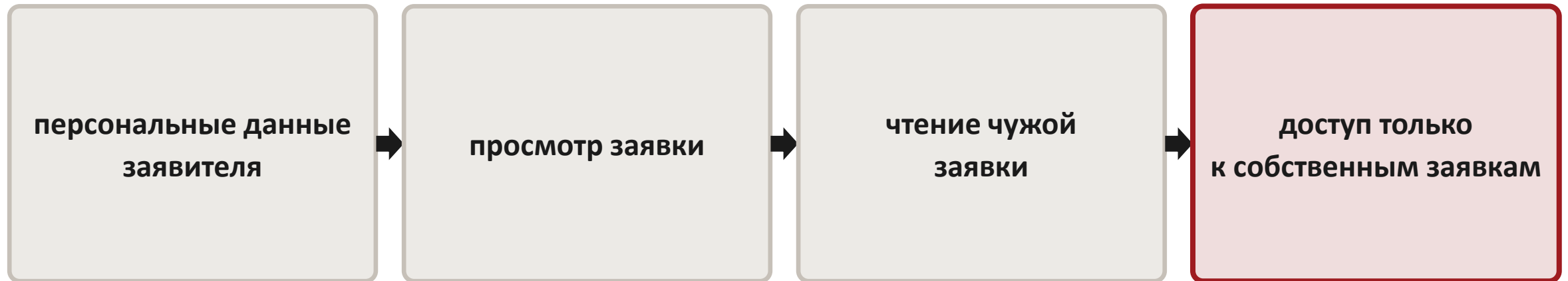


От контекста к защитному свойству

7 / 45



Тот же ход на конкретном примере





Сквозной пример: выдача учебного оборудования

8 / 45

Продукт

студент создаёт заявку на устройство

студент видит состояние своих заявок и может отменить необработанную

кладовщик видит очередь и подтверждает выдачу и возврат

Значимые активы

персональные данные получателей

достоверность реестра оборудования

сведения о текущем владельце устройства

Рабочая цепочка вывода

персональные данные



просмотр заявки студентом



чтение чужой заявки



доступ только к собственным заявкам



Секция 2

Требование и критерий приёмки

Что должно выполняться и по какому наблюдению мы это признаем



Требование безопасности

— проверяемое утверждение о значимом защитном свойстве конкретного продукта. В проекте требование получает устойчивый идентификатор SR и критерий приёмки. Требование описывает, что должно выполняться, но не обязано заранее задавать конкретный механизм реализации.

**Требование описывает свойство продукта,
а не выбранную технологию**



Что должно быть в записи требования

11 / 45

Ядро записи — защитное утверждение и критерий приёмки

SR-идентификатор

УТВЕРЖДЕНИЕ

что должно выполняться

КРИТЕРИЙ ПРИЁМКИ

в какой ситуации какое поведение или состояние наблюдается

ВНУТРЕННЕЕ ОБОСНОВАНИЕ

актив, роль, взаимодействие, недопустимое событие

ВНЕШНИЙ ИСТОЧНИК

нет / не использован

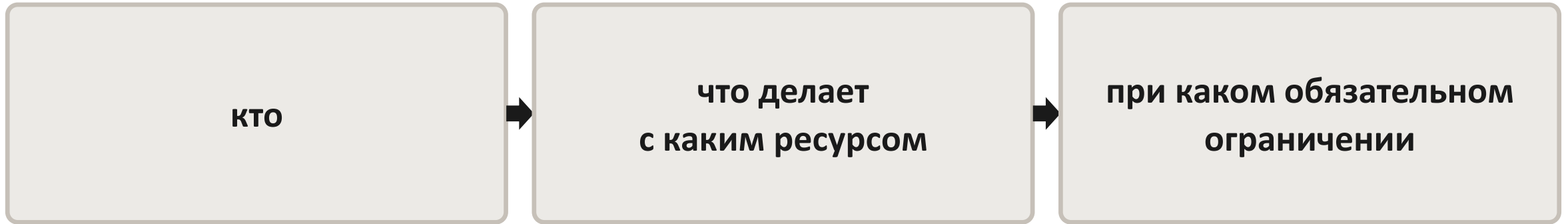
ПРИОРИТЕТ

относительная важность требования



Утверждение требования: что должно выполняться?

12 / 45



**«Студент может просматривать только заявки,
созданные им самим»**

субъект

действие и ресурс

обязательное ограничение



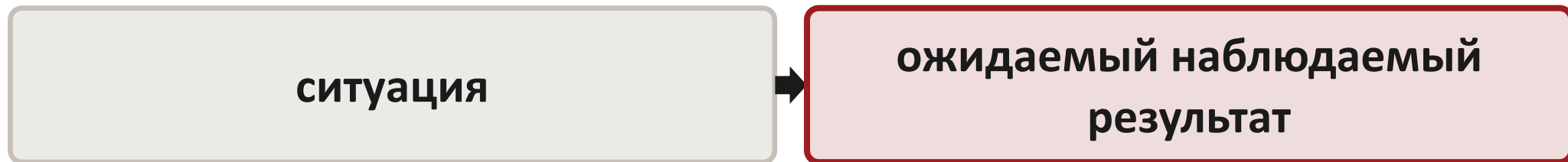
Критерий приёмки: что должно наблюдаться?

13 / 45

Критерий приёмки

— наблюдаемое условие, по которому определяется выполнение требования безопасности SR: в заданной ситуации должно наблюдаться определённое поведение или состояние. Требование без понятного критерия приёмки не считается проверяемым. Критерий приёмки не обязан быть готовым тестом и сам по себе не подтверждает, что требование уже выполнено.

Каноническая форма



Рабочее определение курса



Проверяем и запрет, и полезную функцию

14 / 45

ЗАПРЕЩЁННОЕ

студент запрашивает чужую заявку
→ запрос отклонён без раскрытия
содержимого

РАЗРЕШЁННОЕ

студент запрашивает собственную заявку
→ содержимое доступно

**Полный запрет может пройти негативную проверку
и при этом сломать продукт**



Критерий задаёт границу будущего вывода

15 / 45

SR-01 · студент может просматривать только заявки, созданные им самим

Узкий критерий

студент запрашивает чужую заявку
→ содержимое заявки не возвращается

*Позднее позволит сделать вывод только о чтении
содержимого по проверенному пути*

Расширенный критерий

собственная заявка доступна

чужая заявка отклоняется по обычному маршруту

прямой запрос по идентификатору тоже отклоняется

ответ не раскрывает вложения и метаданные

*Расширяет область будущей проверки и будущего
вывода*

**Граница будущего вывода закладывается
уже при формулировании критерия**



Критерий приёмки ≠ готовый тест

16 / 45

КРИТЕРИЙ ПРИЁМКИ — что должно наблюдаться



СПОСОБ ПРОВЕРКИ — что позднее нужно сделать для наблюдения



ФАКТИЧЕСКИЙ РЕЗУЛЬТАТ — что действительно получено

*на ближайшем семинаре отдельное
поле не обязательно*

*появится только после выполнения
проверки*



Первое требование целиком

17 / 45

SR-01

УТВЕРЖДЕНИЕ

Студент может просматривать только заявки, созданные им самим.

КРИТЕРИЙ ПРИЁМКИ

При обращении студента к идентификатору чужой заявки система отклоняет запрос и не возвращает её содержимое; собственная заявка остаётся доступной.

ВНУТРЕННЕЕ ОБОСНОВАНИЕ

актив — персональные данные получателя; роль — студент; взаимодействие — просмотр заявки

ВНЕШНИЙ ИСТОЧНИК

пока не указан; связь с ASVS не заменит внутреннее обоснование

ПРИОРИТЕТ

высокий — нарушение раскрывает сведения одного пользователя другому



Секция 3

Требование, мера, проверка и свидетельство

Четыре сущности отвечают на четыре разных инженерных вопроса



Четыре разных вопроса

19 / 45

Требование

Что должно
выполняться?

Мера

Как намерены
обеспечить
свойство?

Проверка

Как будем
убеждаться?

Свидетельство

Что фактически
получили?

Эти сущности связаны, но не заменяют друг друга



Защитная мера

20 / 45

Защитная мера

— механизм, ограничение, настройка или проверка, которые реализуют или поддерживают требуемое свойство безопасности. Защитная мера может быть частью последующего проектного решения безопасности.

Требование

студент не получает содержимое чужой заявки



Возможная мера

при каждом серверном обращении к заявке система сопоставляет владельца ресурса с текущим студентом и отклоняет несовпадение



Технология не является требованием

21 / 45

Слабые формулировки

«использовать библиотеку X»

«использовать JWT»

«включить проверку Y»

Устойчивое свойство продукта

**«студент не получает
содержимое чужой заявки»**

*остаётся требованием независимо от выбранного
механизма*

Требование должно сохранять смысл при замене реализации



Будущая проверка ещё ничего не доказывает

22 / 45



Сегодня формируем критерий и можем обсуждать будущий способ проверки

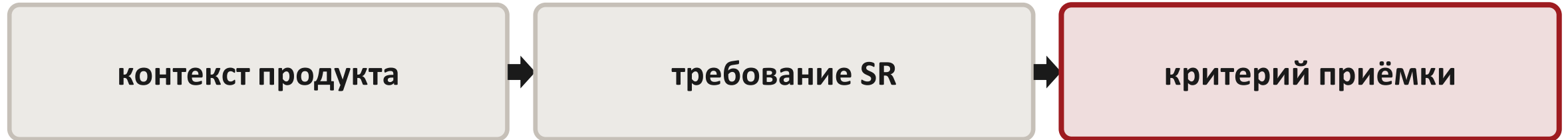
Свидетельство появляется только после фактического результата и его интерпретации



Где мы останавливаемся сегодня

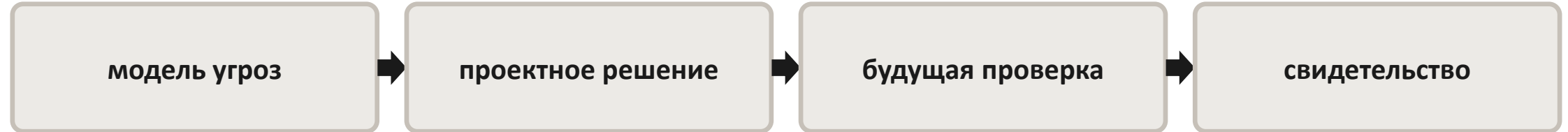
23 / 45

Сегодня



Дальше

позже



- модель угроз — следующая лекция
- проектное решение и его будущая проверка — последующий шаг
- выполненный тест сегодня не требуется



Секция 4

Качество формулировки

Слабое требование нельзя связать ни с решением, ни с проверкой



Хорошее требование выдерживает простую проверку

25 / 45

1 Какое свойство требуется?

2 Какое наблюдаемое поведение считается приемлемым?

3 Можно ли позднее получить результат без догадки автора?

Если ответ зависит от интерпретации автора, требование ещё не готово



Слишком широкая формулировка

26 / 45

Слабая формулировка

«Доступ к заявкам должен быть защищён»

Что здесь нужно уточнить, чтобы появилось проверяемое поведение?

кто

к какому ресурсу

какое действие

при каких условиях

что разрешено

что должно быть отклонено

Рабочая формулировка

«Студент может просматривать только заявки, созданные им самим»



«Использовать X» — мера вместо требования

27 / 45

Слабая формулировка

«Использовать механизм
контроля доступа X»

Что здесь записано:
свойство продукта
или средство его достижения?

Что не определено

для какого ресурса

для каких ролей

какое наблюдаемое поведение обязательно

замена технологии формально меняет «требование», хотя
защитное свойство может остаться тем же

Сначала свойство продукта; технология — позже



Критерий не должен повторять требование

28 / 45

Слабая пара

Требование:
доступ к чужим заявкам запрещён

Критерий:
требование выполнено, если доступ к чужим заявкам
запрещён

Рабочая пара

Требование:
студент может просматривать только собственные
заявки

Критерий:
собственная заявка открывается;
чужая отклоняется без раскрытия содержимого

«Будет протестировано» — тоже не критерий: критерий задаёт ситуацию и ожидаемый результат



Шесть вопросов к собственной формулировке

29 / 45

проверяем формулировку «Доступ к заявкам должен быть защищён»

- | | |
|---|--------------------|
| 1. К какому продукту, компоненту или сценарию относится формулировка? | сценарий не назван |
| 2. Определены ли субъект, ресурс и условия? | нет |
| 3. Можно ли различить успешный и неуспешный результат? | нет |
| 4. Охватывает ли критерий важные обходные пути? | критерия нет |
| 5. Не обещает ли требование больше, чем подтвердит будущая проверка? | обещает всё |
| 6. Останется ли требование осмысленным при замене реализации? | проверять нечего |

Исправленный вариант: студент может просматривать только заявки, созданные им самим; собственная заявка открывается, чужая отклоняется без раскрытия содержимого



Секция 5

Стандарт как источник требований

Стандарт помогает расширять и уточнять, но не знает ваш продукт



Что такое ASVS

31 / 45

ASVS

— каталог проверяемых требований безопасности приложений OWASP. В курсе используется стабильная версия 5.0.0 как источник и справочник требований; знание стандарта целиком не требуется. Ссылка на конкретное требование записывается в формате v5.0.0-X.Y.Z.

**ASVS — справочник для инженерной работы,
а не список, который нужно переписать в проект**

**Идентификаторы между версиями могут меняться:
номер без версии недостаточен**



Что ASVS знает — и чего он не знает

32 / 45

ASVS знает

типовые области безопасности приложений

профессиональные формулировки проверяемых свойств

структуру требований и идентификаторы

ASVS не знает

назначение нашего продукта

конкретные роли

наши активы

последствия нарушения

функции, которых в продукте вообще нет

Применимость устанавливает команда продукта

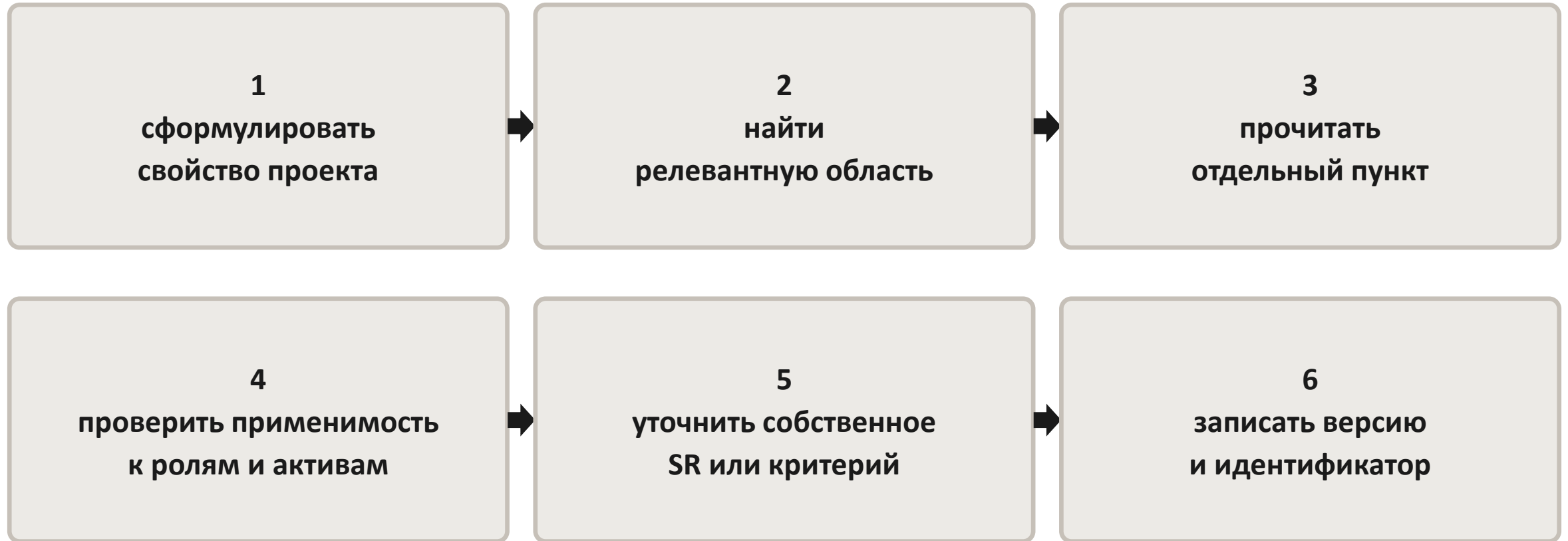
Не каждое требование начинается с предметного правила: основанием могут быть сам актив, взаимодействие или предположение о среде.

ASVS расширяет набор, а последующее моделирование угроз помогает систематически проверить его полноту.



Шесть шагов работы с ASVS

33 / 45



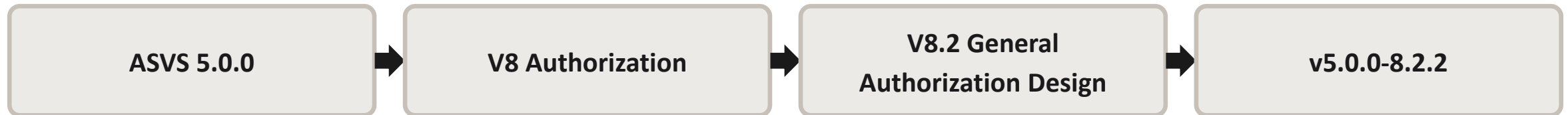
Работа со стандартом начинается с контекста: искать пункт под каждое требование механически не требуется



Живая демонстрация: применимость пункта

34 / 45

«Студент может просматривать только заявки, созданные им самим»



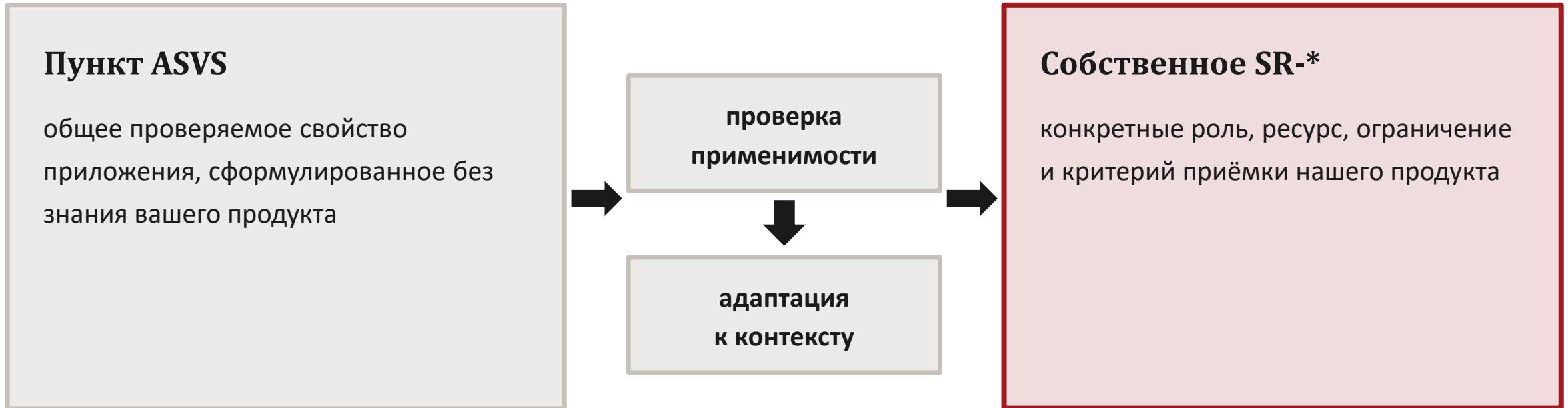
Что проверяем во время демонстрации

- 1** Почему область Authorization релевантна нашему свойству?
- 2** Как требование 8.2.2 соотносится с нашими ролями и заявкой?
- 3** Что оно помогает уточнить в собственном требовании или критерии?



Пункт ASVS ≠ требование проекта

35 / 45



**Проверяющий не должен угадывать,
как общий пункт относится к вашему продукту**



Внутреннее обоснование и внешний источник

36 / 45

SR-01

УТВЕРЖДЕНИЕ

студент может просматривать только заявки, созданные им самим

КРИТЕРИЙ ПРИЁМКИ

при обращении к идентификатору чужой заявки система отклоняет запрос и не возвращает её содержимое

Внутреннее обоснование

актив / роль / взаимодействие / недопустимое событие

Внешний источник

ASVS v5.0.0-8.2.2 — доступ к конкретному объекту данных только с явным разрешением

Внутреннее обоснование отвечает, почему требование нужно этому продукту.

Внешний источник показывает, какой профессиональный ориентир использован для расширения или уточнения.



Две роли стандарта: расширить и уточнить

37 / 45

Расширить

после первичного вывода требований
просмотреть релевантные области и обнаружить
классы свойств, которые не были очевидны из
предметных правил

Уточнить

использовать профессиональную формулировку,
чтобы сделать собственное свойство или
критерий конкретнее

**Окончательное требование остаётся требованием конкретного продукта,
а его применимость объясняется через контекст**



Секция 6

Приоритет, трассируемость и живой реестр

Набор требований должен управляться и изменяться вместе с продуктом



Три требования одного продукта

39 / 45

SR-01

конфиденциальность заявки

Утверждение
студент может просматривать
только заявки, созданные им
самим

Критерий
собственная заявка доступна;
чужая отклоняется без раскрытия
содержимого

SR-02

целостность реестра оборудования

Утверждение
подтверждать выдачу и возврат
устройства может только
кладовщик

Критерий
попытка студента изменить
состояние выдачи отклоняется;
корректная операция кладовщика
выполняется

SR-03

достоверность текущего владельца

Утверждение
изменение текущего владельца
происходит только как результат
подтверждённой операции
выдачи или возврата

Критерий
прямое изменение владельца вне
такой операции отклоняется

Какому требованию уделять внимание раньше и на каком основании?



Приоритет — это очередность внимания

40 / 45

Основания сравнения

значимость затрагиваемого актива	возможные последствия нарушения	охват пострадавших	роль функции в основном сценарии
----------------------------------	---------------------------------	--------------------	----------------------------------

Высокий приоритет ≠ написать требование максимально строго	Низкий приоритет ≠ забыть требование
---	---

**Приоритет — решение об очередности внимания и проверки,
а не характеристика строгости текста требования**

SR-01 — высокий · SR-02 — высокий · SR-03 — средний

<i>Учебное предварительное решение для данного контекста; в реальном проекте приоритет фиксируется вместе с обоснованием последствий и охвата</i>



Реестр требований — живой артефакт

Изменения

- новая роль
- новый интерфейс
- изменение границы
- новое предположение
- новые результаты моделирования угроз



	Свойство	Критерий приёмки	Приоритет	Происхождение
SR-01	конфиденциальность заявки	собственная доступна, чужая отклоняется	высокий	персональные данные
SR-02	целостность реестра оборудования	изменение состояния выдачи студентом отклоняется	высокий	достоверность реестра
SR-03	достоверность текущего владельца	изменение владельца вне операции отклоняется	средний	сведения о владельце

пересмотреть набор, формулировки, критерии и приоритеты требований

Изменение требования может потребовать обновить последующее решение и проверку

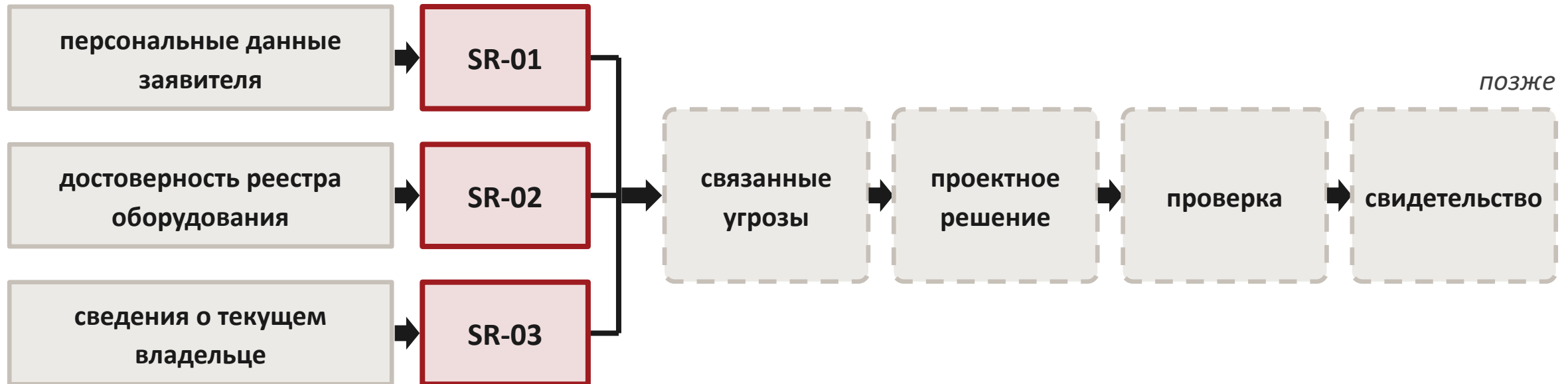
позже



Трассируемость работает в обе стороны

42 / 45

Трассируемость — возможность проследить, почему существует требование или решение, с какой угрозой оно связано и каким результатом подтверждается.



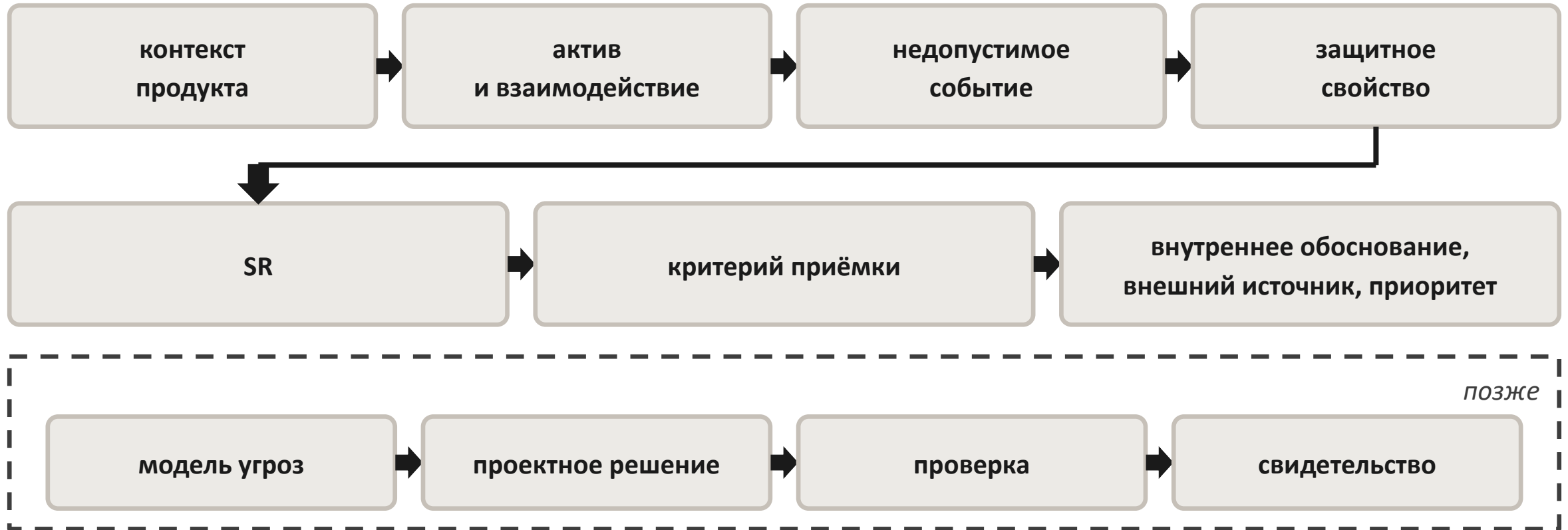
← **ОБРАТНОЕ ЧТЕНИЕ:** результат → что подтверждает → какое решение → какое SR → почему SR существует

Рабочее определение курса



Вся лекция — в одной цепочке

43 / 45



- не каждое требование начинается с бизнес-правила, но каждое обосновано в контексте продукта
- ASVS помогает расширить и уточнить, но не заменяет контекст

- критерий задаёт наблюдаемое поведение и границу будущего вывода
- реестр требований развивается вместе с продуктом



Сформулировать проверяемые требования безопасности из контекста продукта

На занятии

- отличить предметные правила от требований
- исправить слабые формулировки учебного кейса
- сформулировать требования своего проекта
- добавить предварительные критерии приёмки
- в одном подходящем случае обратиться к ASVS

Пока не требуются

- модель угроз
- STRIDE
- проектное решение
- работающий сервер
- готовые автоматизированные тесты
- фактическое свидетельство

Ориентир к концу занятия — 2–3 содержательных требования

